iCReaT 시스템 보안 점검 보고서

Nov 5, 2026 · @길윤정

1. 개요 및 점검 목적

본 보고서는 iCReaT(임상연구관리시스템)의 설계·운영상 보안 취약 가능성을 5대 영역으로 나누어 점검하고, 외주 운영사에 요구할 증빙과 단계별 이행 계획을 제시한다.

1.1 점검 대상

구분	내용
대상 시스템	iCReaT 웹 기반 임상연구 데이터 관리 플랫폼
취급 정보	연구 과제 정보, 연구대상자 개인정보, 임상·건강정보(민감정보)
권한 체계	일반 과제 담당자(소속 과제만 조회·다운로드), 최고 관리자(전체 과제 통합 조회·일괄 다운로드)
인증 방식	계정·비밀번호, 3개월 주기 변경 정책
운영 구조	외주 업체 개발·운영, 데이터 백업 시스템 및 관리자 전용 서버 접근 경로 운영

1.2 점검 목적

- 과제 간 데이터 격리, 관리자 권한 보호 등 핵심 통제가 설계대로 작동하는지 확인함
- 외주 운영 구조에서 발생할 수 있는 비인가 접근 경로를 식별함
- 개인정보 보호법상 안전성 확보조치 이행 여부를 사전 점검하여 법적 위험을 줄임
- 외주 운영사로부터 서면 증빙을 받아 통제 수준을 객관적으로 확인함

1.3 점검 방식 및 기준

- 방식: 문서·설정 검토 및 외주사 서면 소명 기반의 자체 점검. 운영 시스템에 대한 직접 침투 시험은 포함하지 않으며, 필요 시 승인된 범위에서 전문기관 모의해킹으로 별도 수행함
- 기준: 개인정보 보호법 및 개인정보의 안전성 확보조치 기준, ISMS-P 인증기준, OWASP API Security Top 10(2023), OWASP ASVS

1.4 위험도 정의

위험도	정의	조치 시점
Critical	대량 개인정보 유출 또는 시스템 전체 통제권 상실로 직결될 수 있음	즉시(단기)
High	단독 또는 다른 취약점과 결합 시 중대한 유출·침해로 이어질 수 있음	단기~중기
Medium	피해 범위가 제한적이거나 보완 통제로 위험을 낮출 수 있음	중기~장기

2. 주요 보안 점검 항목

각 항목은 ① 점검 항목명 및 위험도, ② 현상 및 예상 시나리오, ③ 시스템 영향도, ④ 외주사 확인 및 기술적 보완 요구사항 순으로 작성하였다. 예상 시나리오는 취약점 존재를 확인한 것이 아니라 점검이 필요한 가능성을 기술한 것이다.

2.1 접근 권한 통제 (수평·수직 권한 상승)

① 점검 항목명 및 위험도: 객체 및 기능 단위 접근 권한 검증 — **Critical**

- 전문 보안 개념: 객체 수준 권한 검증 미흡(BOLA, OWASP API1), 기능 수준 권한 검증 미흡(BFLA, OWASP API5), 속성 수준 권한 검증 미흡(Mass Assignment, OWASP API3)
- 쉽게 이해하는 개요: 로그인한 사용자가 "누구인가"만 확인하고 "이 자료를 볼 자격이 있는가"는 매번 확인하지 않으면, 자기 과제가 아닌 자료에도 접근할 수 있게 되는 문제임

② 현상 및 예상 시나리오

- 수평적 권한 상승: 일반 담당자가 요청 속 과제·대상자·파일 식별번호를 타 과제 값으로 바꾸어 요청할 때, 서버가 소속 여부를 검증하지 않으면 타 과제 데이터가 조회·다운로드됨. 식별번호가 순차 번호이면 추정이 쉬워 위험이 커짐
- 수직적 권한 상승: 관리자 메뉴가 화면에서만 숨겨져 있고 서버측 역할 검증이 없으면, 일반 계정이 관리자 기능 주소를 직접 호출해 전체 조회·사용자 관리 기능을 사용할 수 있음
- 권한 정보 변조: 권한 판단을 클라이언트가 보내는 값(역할 필드, 쿠키 등)에 의존하거나, 정보 수정 시 권한 필드까지 변경되도록 허용하면 권한이 임의로 상승될 수 있음

③ 시스템 영향도

- 데이터 유출: 과제 간 격리 원칙이 무너져 단일 계정으로 전체 과제의 임상·개인정보 열람 및 반출이 가능해짐
- 시스템 통제: 수직적 상승 시 최고 관리자 권한 탈취와 동일한 효과로, 계정·설정 변조까지 이어짐
- 법적 책임: 민감정보 유출 사고로 개인정보 보호법상 유출 통지·신고 의무 및 과징금·과태료 대상이 될 수 있음

④ 외주사 확인 및 기술적 보완 요구사항

- 모든 조회·수정·다운로드 요청에 대해 서버측에서 요청자의 과제 소속·역할을 검증하는지 확인하고, 검증 로직의 적용 범위를 제시하도록 요구함
- 역할별 권한 매트릭스(역할 × 기능 × 허용 여부)를 문서로 제출하도록 요구함
- 외부에 노출되는 식별번호는 추정 불가한 값(UUID 등)으로 전환하고, 권한 판단은 서버 세션 정보만을 기준으로 하도록 보완을 요구함
- 수정 요청에서 허용된 필드만 반영하도록(허용 목록 방식) 개선을 요구함

2.2 비인가 접근 경로 (백도어·외주 유지보수 채널·백업)

① 점검 항목명 및 위험도: 정규 인증을 우회하는 접근 경로 및 외주사 접근 통제 — **Critical**

- 전문 보안 개념: 하드코딩된 자격증명(Hard-coded Credentials), 기본 계정·비밀번호 미변경, 테스트·디버그 기능 잔존, 원격 유지보수 채널 통제 미흡, 공유 계정, 백업 데이터 보호 미흡, 공급망 보안
- 쉽게 이해하는 개요: 개발·유지보수 편의를 위해 만들어 둔 별도 출입구나 예비 계정이 운영 후에도 남아 있으면, 정식 로그인 절차를 거치지 않고도 시스템에 들어올 수 있는 문제임

② 현상 및 예상 시나리오

- 소스코드·설정파일에 관리용 계정, DB 비밀번호, API 키가 평문으로 포함되어 있고, 소스나 배포본이 유출되면 해당 정보로 직접 접근이 가능해짐
- 개발 단계의 테스트 계정, 디버그용 페이지, API 문서 페이지가 운영 환경에 남아 내부 구조가 노출되거나 인증 없이 기능이 호출됨
- 원격 유지보수 경로(VPN, 원격접속, 백업 서버 접근 등)를 여러 직원이 하나의 계정으로 공유하거나, 퇴사자 계정이 회수되지 않아 접속 주체 확인이 불가능함
- 백업 데이터가 암호화 없이 보관되거나 접근 통제가 운영 서버보다 느슨하여, 전체 데이터가 한 번에 유출되는 지점이 됨

③ 시스템 영향도

- 데이터 유출: 권한 통제·인증 절차 전체를 우회하므로 전체 데이터가 유출될 수 있으며, 정상 접근과 구분되지 않아 탐지가 어려움
- 책임 추적: 공유 계정 사용 시 행위자 특정이 불가능하여 사고 원인 규명과 책임 소재 확인이 어려움
- 법적 책임: 개인정보 처리 위탁자로서 수탁자(외주사) 관리·감독 의무가 있으므로, 외주사 관리 미흡으로 인한 사고도 기관 책임으로 귀결될 수 있음

④ 외주사 확인 및 기술적 보완 요구사항

- 소스코드·설정파일 내 하드코딩 비밀정보 자동 점검 결과와 비밀정보 보관 방식(별도 비밀정보 관리 체계 등)을 제출하도록 요구함
- 운영 환경의 전체 계정 목록과 API 엔드포인트 목록을 제출하고, 테스트·디버그 기능 제거 여부를 소명하도록 요구함
- 원격 접속 경로에 개인별 계정, 다중 인증, 접속 IP 제한, 접속 기록 보관을 적용하도록 요구함

- 백업 데이터 암호화, 백업 접근 권한자 최소화, 백업 접근 기록 보관을 적용하도록 요구함
- 사용 중인 오픈소스·외부 라이브러리 목록과 취약점 관리 현황을 제출하도록 요구함

2.3 인증 및 세션 관리

① 점검 항목명 및 위험도: 사용자 인증 강도 및 세션 안전성 — **High**

- 전문 보안 개념: 반복 로그인 시도 제한 부재(무차별 대입 공격·타 사이트 유출 계정 대입), 세션 고정(Session Fixation), 세션 탈취·재사용, 다중 인증(MFA) 부재, 취약한 비밀번호 정책 (OWASP API2)
- 쉽게 이해하는 개요: 3개월마다 비밀번호를 바꾸더라도, 틀린 비밀번호를 무제한 입력할 수 있거나 한 번 발급된 로그인 상태(세션)를 타인이 그대로 쓸 수 있다면 계정 보호 효과가 크게 떨어짐

② 현상 및 예상 시나리오

- 로그인 실패 횟수 제한·계정 잠금·자동화 방지 장치가 없으면, 자동화된 반복 시도나 타 서비스 유출 계정 대입으로 계정이 탈취될 수 있음
- 로그인 전후에 세션 식별자가 재발급되지 않으면, 사전에 확보된 세션으로 인증 상태를 가로채는 세션 고정이 발생할 수 있음
- 세션 만료 시간이 길거나 로그아웃 시 서버측 무효화가 없으면, 유출된 세션이 장기간 재사용됨
- 쿠키 보호 속성(Secure·HttpOnly·SameSite), HTTPS 강제(HSTS) 미적용 시 세션 정보가 노출될 수 있음
- 주기적 변경만 강제하고 복잡도·재사용 금지 기준이 약하면, 숫자만 바꾸는 등 예측 가능한 비밀번호가 양산됨

③ 시스템 영향도

- 데이터 유출: 탈취된 계정은 정상 사용자로 인식되어, 해당 계정 권한 범위의 데이터가 탐지 없이 유출될 수 있음
- 시스템 통제: 최고 관리자 계정이 탈취되면 전체 과제 데이터와 시스템 설정이 노출되는 단일 실패 지점이 됨
- 법적 책임: 개인정보의 안전성 확보조치 기준의 접근 통제·인증 관련 조치 미흡으로 판단될 수 있음

④ 외주사 확인 및 기술적 보완 요구사항

- 로그인 실패 허용 횟수, 잠금 시간, 자동화 방지 장치 적용 여부를 설정값으로 제시하도록 요구함
- 최고 관리자 및 외부 접속 계정에 다중 인증을 적용하도록 요구함
- 로그인 시 세션 재발급, 유휴 시간 자동 종료, 로그아웃 시 서버측 세션 폐기, 동시 접속 제어 적용 여부를 시험 결과로 제시하도록 요구함
- 쿠키 보호 속성 및 TLS 설정(버전·HSTS) 현황을 제출하도록 요구함
- 비밀번호 길이·복잡도·재사용 금지 기준을 강화하고, 주기적 변경 정책의 실효성을 재검토하도록 요구함

2.4 파일 다운로드 및 객체 직접 참조 (대량 유출)

① 점검 항목명 및 위험도: 파일 다운로드 경로의 접근 통제 및 대량 반출 방지 — **Critical**

- 전문 보안 개념: 안전하지 않은 객체 직접 참조(IDOR), 만료·서명 없는 다운로드 URL, 식별자 열거(Enumeration), 과다한 데이터 노출, 자원 사용 제한 부재 (OWASP API3·API4)
- 쉽게 이해하는 개요: 다운로드 주소에 파일 번호만 들어 있고 권한을 다시 확인하지 않으면, 주소를 알거나 번호를 바꾸는 것만으로 다른 파일을 내려받을 수 있고, 이를 자동화하면 전체 자료를 일괄 반출할 수 있는 문제임

② 현상 및 예상 시나리오

- 다운로드 요청마다 권한을 재검증하지 않고 순차적인 파일 번호만으로 파일을 제공하면, 번호 변경만으로 타 과제 파일에 접근됨
- 임시 다운로드 링크에 유효기간·사용 횟수 제한이 없으면, 메일·메신저·브라우저 기록 등으로 링크가 노출될 때 제3자가 재사용함
- 요청 속도·다운로드량 제한이 없으면 단일 계정으로 짧은 시간에 대량 데이터를 자동 수집할 수 있음
- 화면에 필요한 것보다 많은 정보(식별정보, 내부 코드 등)가 응답에 포함되고 화면에서만 가려지면, 응답 내용을 직접 확인하여 정보가 노출됨

③ 시스템 영향도

- 데이터 유출: 단건 노출이 아니라 연구대상자 전체의 임상·건강정보 대량 유출로 번질 수 있음
- 탐지 난이도: 정상 로그인 후의 다운로드로 보여 경계 보안 장비만으로는 식별이 어려움
- 법적 책임: 대규모 민감정보 유출로 정보주체 통지·신고, 과징금, 손해배상, 연구 신뢰도 훼손으로 이어질 수 있음

④ 외주사 확인 및 기술적 보완 요구사항

- 다운로드 URL 구조와 식별자 생성 방식(순차 번호 여부)을 제시하도록 요구함
- 다운로드 요청마다 서버측 권한 재검증을 적용하고, 링크에 짧은 유효기간·일회성·서명을 적용하도록 요구함
- 계정별 요청 속도 제한, 다운로드량 상한, 대량 다운로드 사전 승인 절차를 도입하도록 요구함
- API 응답에서 화면에 필요하지 않은 항목을 제거하고, 다운로드 파일의 비식별·가명처리 적용 범위를 제시하도록 요구함

2.5 감사 로그 및 이상행위 모니터링

① 점검 항목명 및 위험도: 관리자 행위 기록·보존 및 실시간 탐지 체계 — **High**

- 전문 보안 개념: 감사 추적(Audit Trail) 범위 부족, 로그 무결성 미보장, 실시간 경보 부재, 관리자 이상행위 탐지 기준 부재, 직무 분리 미흡 (OWASP Top 10 A09)
- 쉽게 이해하는 개요: 누가 언제 어떤 자료를 보고 내려받았는지 기록이 남지 않거나, 기록이 지워질 수 있거나, 아무도 기록을 확인하지 않으면 사고가 나도 알아차리지 못하고 원인도 밝힐 수 없는 문제임

② 현상 및 예상 시나리오

- 로그인은 기록되지만 조회·다운로드·권한 변경·설정 변경 등 핵심 행위가 누락되면, 데이터 반출 여부를 사후에 확인할 수 없음
- 로그가 운영 서버에만 저장되고 관리자가 수정·삭제할 수 있으면, 침해자 또는 오·남용자가 흔적을 지울 수 있음
- 야간 관리자 접속, 비승인 IP 접속, 평소 대비 급증한 다운로드에 대한 경보 규칙이 없으면, 로그가 있어도 침해를 실시간으로 인지하지 못함
- 최고 관리자는 전체 접근이 정상 권한이므로, 정상 업무 범위에 대한 기준선이 없으면 오·남용을 구분할 수 없음
- 로그 검토 주체와 시스템 운영 주체가 동일(외주사)하면 자기 점검에 그치게 됨

③ 시스템 영향도

- 데이터 유출: 로그 결함은 직접 유출을 일으키지는 않으나, 2.1~2.4의 모든 위협에 대한 탐지·대응·원인 분석을 불가능하게 하여 피해를 키우는 요인이 됨
- 법적 책임: 개인정보처리시스템 접속기록의 보관·정기 점검은 개인정보의 안전성 확보조치 기준의 의무사항으로, 미흡 시 그 자체로 법적 미준수가 됨
- 사고 대응: 유출 범위·시점을 특정하지 못하면 정보주체 통지와 기관 신고를 정확히 수행하기 어려움

④ 외주사 확인 및 기술적 보완 요구사항

- 현재 기록하는 로그 항목(행위자·일시·접속지·대상 데이터·수행 업무) 목록과 실제 로그 샘플을 제출하도록 요구함
- 로그를 운영 서버와 분리된 저장소에 보관하고, 수정·삭제 방지 조치를 적용하도록 요구함
- 법적 보관기간 이상 로그를 보관하고, 보관 정책을 문서로 제출하도록 요구함
- 이상행위 경보 규칙(야간 접속, 비승인 IP, 대량 다운로드, 권한 변경)을 수립하고, 경보가 기관 담당자에게도 전달되도록 요구함
- 기관 담당자가 직접 로그를 열람·점검할 수 있는 수단을 제공하도록 요구함

3. 외주 운영사 제출 요구 서면 증빙 체크리스트

외주 운영사는 각 항목에 대해 "적용/미적용" 답변에 그치지 않고 **증빙 자료를 첨부하여 서면으로 회신**하여야 한다. 미조치 항목은 조치 계획과 완료 예정일을 함께 제출한다.

구분	점검 항목	외주사 제출 필요 증빙 자료	확인 포인트
2.1 권한	객체 단위 소유·소속 검증	권한 검증 로직 적용 범위 설명서, 타 과제 식별자 요청 시 차단 시험 결과(화면·로그)	조회·수정·다운로드 전 기능에 적용되었는지, 일부 화면에만 적용된 것은 아닌지

구분	점검 항목	외주사 제출 필요 증빙 자료	확인 포인트
2.1 권한	기능 단위 역할 검증	역할별 권한 매트릭스, 일반 계정의 관리자 기능 호출 차단 시험 결과	화면 숨김이 아니라 서버측에서 차단되는지
2.1 권한	권한 정보 변조 방지	권한 판단 근거(세션·토큰) 설명, 수정 가능 필드 허용 목록	권한을 클라이언트 전송값에 의존하지 않는지
2.2 비인가 경로	하드코딩 비밀정보 제거	소스코드 비밀정보 자동 점검 결과 보고서, 비밀정보 보관 방식 설명서	점검 도구·일자·대상 범위가 명시되어 있는지, 운영 배포본 기준인지
2.2 비인가 경로	테스트·디버그 계정 및 기능 제거	운영 환경 전체 계정 목록, 전체 API 엔드포인트 목록, 삭제·비활성화 이력	목록에 용도 불명 계정·엔드포인트가 없는지, 기본 비밀번호 변경 여부
2.2 비인가 경로	원격 유지보수 채널 통제	원격 접속 경로 구성도, 허용 IP 목록, 다중 인증 설정, 최근 3개월 접속 기록	구성도에 없는 경로가 접속 기록에 나타나지 않는지
2.2 비인가 경로	외주사 계정 개인화·회수	직원별 계정 대장, 권한 부여·회수 이력, 퇴사자 계정 삭제 기록	공유 계정이 없는지, 투입 인력 현황과 계정 수가 일치하는지
2.2 비인가 경로	백업 데이터 보호	백업 보관 위치·주기, 암호화 적용 증빙, 백업 접근 권한자 목록 및 접근 기록	백업이 운영 서버와 동등 이상으로 보호되는지
2.2 비인가 경로	외부 라이브러리 관리	사용 오픈소스·라이브러리 목록(버전 포함), 취약점 점검·패치 이력	알려진 취약 버전을 사용하고 있지 않은지
2.3 인증	로그인 실패 제한·다중 인증	인증 정책 설정 화면(실패 허용 횟수, 잠금 시간), 다중 인증 적용 대상 목록	최고 관리자·외부 접속 계정이 다중 인증 대상에 포함되는지
2.3 인증	세션 관리	세션 재발급·만료·폐기 시험 결과, 쿠키 보호 속성 및 TLS·HSTS 설정 현황	로그아웃 후 기존 세션이 재사용되지 않는지
2.3 인증	비밀번호 정책	비밀번호 길이·복잡도·재사용 금지 기준, 비밀번호 암호화 저장 방식	비밀번호가 일방향 암호화로 저장되는지
2.4 다운로드	다운로드 URL·식별자 구조	다운로드 URL 구조 설명, 식별자 생성 방식, 링크 유효기간 설정값	식별자가 순차 번호가 아닌지, 링크 재사용이 차단되는지
2.4 다운로드	대량 다운로드 제한	계정별 요청 속도 제한·다운로드량 상한 설정값, 초과 시 처리 절차	상한 초과 시 차단 또는 승인 절차가 실제 동작하는지
2.4 다운로드	응답 데이터 최소화	주요 API 응답 항목 목록, 비식별·가명처리 적용 범위	화면에 표시되지 않는 개인정보가 응답에 포함되지 않는지

구분	점검 항목	외주사 제출 필요 증빙 자료	확인 포인트
2.5 감사 로그	로그 기록 범위	로그 설계서(기록 항목), 다운로드·권한 변경 로그 실제 샘플	행위자·일시·접속지·대상·업무가 모두 기록되는지
2.5 감사 로그	로그 무결성·보관	로그 저장 위치, 수정·삭제 방지 설정, 보관기간 정책 문서	관리자 권한으로도 로그 삭제가 불가한지, 법적 보관기간을 충족하는지
2.5 감사 로그	이상행위 경보	경보 규칙 목록, 경보 수신자, 최근 경보 발생 및 대응 이력	기관 담당자에게도 경보가 전달되는지
공통	정기 보안 점검	최근 취약점 진단·모의해킹 보고서, 지적 사항 조치 이력	점검 수행 주체가 독립적인지, 지적 사항이 모두 조치되었는지

회신 검토 기준

- 증빙 없이 "조치 완료"만 회신된 항목은 미확인으로 분류하고 재요청함
- "확인 불가" 또는 "기록 없음"으로 회신된 항목은 통제 부재로 간주하여 단기 조치 대상에 포함함
- 미조치 항목은 완료 예정일을 기준으로 이행 여부를 재점검함

4. 단계별 조치 및 관리 이행 로드맵

조치는 위험도와 적용 난이도를 기준으로 3단계로 추진하며, 단계별 완료 여부는 3장의 증빙으로 확인한다. 세부 일정과 담당은 외주사 회신 후 확정한다.

4.1 단기 (1개월 이내) — 즉시 위험 차단

대상	조치 내용	관련 항목	완료 기준
증빙 요구	3장 체크리스트를 공문으로 발송하고 회신 기한 설정	전체	항목별 증빙 회신 완료
관리자·외부 접속	최고 관리자 및 외주사 원격 접속에 다중 인증 적용	2.2, 2.3	대상 계정 100% 적용
로그인 보호	로그인 실패 횟수 제한·계정 잠금 활성화	2.3	설정값 확인
계정 정비	공유 계정 폐지, 퇴사자·테스트 계정 삭제, 기본 비밀번호 변경	2.2	계정 대장과 실제 계정 일치
비밀정보	하드코딩된 비밀정보 점검 및 제거, 노출 가능성 있는 비밀번호 교체	2.2	자동 점검 결과 보고서
경보	야간 관리자 접속·대량 다운로드·권한 변경 경보 규칙 수립	2.5	기관 담당자 경보 수신 확인

4.2 중기 (3개월 이내) — 구조적 취약점 보완

대상	조치 내용	관련 항목	완료 기준
권한 통제	전 기능에 서버측 객체·기능 권한 검증 적용, 역할별 권한 매트릭스 확정	2.1	차단 시험 결과 제출
다운로드	추정 불가 식별자 전환, 링크 유효기간·일회성 적용, 요청마다 권한 재검증	2.4	URL 구조 변경 확인
대량 유출 방지	요청 속도 제한, 다운로드량 상한, 대량 다운로드 사전 승인 절차 도입	2.4	상한 초과 시 차단 확인
세션	세션 재발급·자동 종료·서버측 폐기, 쿠키 보호 속성·HSTS 적용	2.3	세션 시험 결과
응답 최소화	API 응답의 불필요 항목 제거, 다운로드 파일 비식별·가명처리 적용	2.4	응답 항목 목록 검토
로그 체계	로그 항목 표준화, 분리 저장·변조 방지, 법적 보관기간 준수	2.5	로그 샘플·설정 확인
백업	백업 데이터 암호화, 접근 권한자 최소화, 접근 기록 보관	2.2	암호화 증빙

4.3 장기 (6개월~1년) — 관리체계 정착

대상	조치 내용	관련 항목	완료 기준
관리자 통제	전체 데이터 일괄 다운로드 시 2인 승인·목적 기록, 관리자 행위 기준선 수립	2.1, 2.5	승인 절차 시행
권한 검토	분기별 계정·권한 정기 검토	2.1, 2.2	분기별 검토 결과 보고
계약·위탁 관리	외주 계약에 보안 의무(정기 점검, 사고 즉시 보고, 계정·비밀정보 관리) 명시, 수탁자 연 1회 이상 점검	공통	계약 반영, 점검 결과 보고
독립 점검	외부 전문기관 모의해킹 연 1회 이상(사전 승인 범위 내), 주기적 취약점 진단	공통	점검 보고서 및 조치 이력
법적 준수	개인정보의 안전성 확보조치 기준·ISMS-P 기준 자체 점검 및 개선	공통	자체 점검 결과서
사고 대응	개인정보 유출 대응 절차 수립 및 모의 훈련	2.5	대응 절차서, 훈련 결과

4.4 이행 관리

- 단계별 완료 여부는 외주사 제출 증빙으로 확인하며, 증빙이 없는 항목은 미완료로 관리함
- 월 1회 이행 현황을 점검하고, Critical 항목 지연 시 상위 보고함
- 운영 시스템에 대한 직접 시험은 승인된 범위에서 보안 담당 부서 또는 전문기관이 수행함